

CVE-2023-23397

OUTLOOK FORCED NTLM AUTHENTICATION

A telemetry-led hunting and validation model for Outlook reminder abuse, outbound SMB and WebDAV fallback evidence.

HUNTING QUERY

CONFIDENCE: MEDIUM

REPORT DATE

31 July 2026

PRIMARY PLATFORM

Microsoft Defender XDR

PRIMARY TELEMETRY

AlertInfo | DeviceNetworkEvents | DeviceProcessEvents

ATT&CK

T1187 - Forced Authentication

EVIDENCE HIERARCHY

- MAPI property confirms exploit delivery.
- Public SMB supports a credential-leak attempt.
- WebDAV supports fallback activity, not hash leakage.

01

Executive Assessment

What can be detected, inferred and confirmed.

No single endpoint event proves the CVE.

The defensible workflow combines a CVE-specific Defender for Office 365 alert or direct inspection of PidLidReminderFileParameter with endpoint evidence of public SMB or WebDAV fallback. A click is neither required nor proof.

Publish as hunting, not production.

Defender XDR exposes documented alert, network and process schemas, but a reliable message-to-device correlation key is environment-dependent. This blocks a production-ready correlation.

MEDIUM

CONFIDENCE



3 LAYERS

EVIDENCE MODEL



HUNTING

READINESS



SOURCE FACTS

Outlook on Windows processes a crafted reminder property. An external UNC path can trigger SMB and Net-NTLMv2 negotiation. No user interaction is required.

ASSESSMENT

Mailbox/MAPI evidence is CVE-specific. Public SMB is a credential-access lead. The documented rundll32 pattern supports WebDAV fallback.

ASSUMPTIONS

MDO alerts are retained. MDE covers the affected endpoint. Process command lines and network fields are populated consistently.

CRITICAL BOUNDARY

A click, a TCP/445 event or a WebDAV process alone cannot establish that CVE-2023-23397 was exploited or that credentials were leaked.

02

Threat Mechanics

Evidence-bearing stages from crafted message to authentication attempt.



STAGE	OBSERVABLE EVIDENCE	DETECTION VALUE	DOES NOT PROVE
Delivery	InternetZone UNC in PidLidReminderFileParameter.	CVE-specific confirmation.	Endpoint trigger.
Trigger	MDO alert or mailbox scan result.	High-value message evidence.	Credential leakage.
SMB	Public TCP/445; optional NTLM signature.	Credential-leak attempt.	CVE causation.
WebDAV	rundll32 davclnt.dll,DavSetCookie under WebClient.	Fallback evidence.	Net-NTLMv2 leakage.
Post-exploit	External NTLM auth, relay or mailbox access.	Compromise assessment.	Initial vector without prior evidence.

STRONGEST ANCHOR

An extended MAPI reminder property referencing an InternetZone UNC location is the most direct evidence of exploit delivery.

ENDPOINT BOUNDARY

Traditional endpoint forensics may retain few artifacts. Absence of endpoint evidence does not exclude delivery or a historical trigger.

03

Telemetry & Evidence Model

Required, optional and unavailable evidence across platforms.

PRIMARY PLATFORM · DEFENDER XDR

AlertInfo, DeviceNetworkEvents and DeviceProcessEvents provide the most direct documented combination of product alert, SMB and WebDAV evidence.

REQUIRED EXTERNAL EVIDENCE

The Microsoft Exchange scan or an equivalent verified method is required to inspect PidLidReminderFileParameter.

LAYER	SOURCE / FIELDS	RELIABILITY	ROLE
Required	AlertInfo: Timestamp, AlertId, Title, ServiceSource.	Schema documented; title local.	CVE alert discovery.
Required	DeviceNetworkEvents: RemoteIP, RemotePort, RemoteIPType, device.	Fields documented.	Public SMB behavior.
Optional	DeviceProcessEvents: command lines and initiating process.	Population varies.	WebDAV fallback.
Optional	Exchange scan CSV: item identity, property value, zone.	Microsoft workflow.	Exploit confirmation.
Unavailable	Guaranteed message-to-device correlation key.	Unverified.	Blocks production.

PLATFORM	DECISION	MISSING VALIDATION
Defender XDR	Primary hunting and validation.	Alert titles, field population and baseline.
Microsoft Sentinel	Only with Defender XDR event streaming.	Connector and workspace tables.
SentinelOne	No reliable generic query.	Customer schema and raw Deep Visibility event.
Splunk	No reliable implementation can currently be written.	Index, sourcetype and field extractions.
Chronicle	No reliable implementation can currently be written.	Parser, UDM mapping and populated fields.

VISIBILITY GAP

Public hunting schemas do not guarantee direct access to the raw extended MAPI property. Mailbox scanning remains the authoritative confirmation path.

04

Detection Logic

Three atomic evidence queries; correlation remains analyst-led.

CLASSIFICATION · HUNTING QUERY · CONFIDENCE MEDIUM

Query A validates a CVE-specific product alert. Queries B and C expose corroborating behaviors and must not be treated as attribution.

```
// A - CVE-specific MDO alert validation
AlertInfo
| where Timestamp > ago(30d)
| where ServiceSource == "Microsoft Defender for Office 365"
| where Title startswith "Exploit_Office_CVE_2023_23397_"
| project Timestamp, AlertId, Title, Severity, Category, ServiceSource

// B - public outbound SMB; behavior, not attribution
DeviceNetworkEvents
| where Timestamp > ago(30d) and RemotePort == 445
| where isnotempty(RemoteIP)
| where RemoteIPType == "Public" or not(ipv4_is_private(RemoteIP))
| project Timestamp, DeviceName, RemoteIP, RemotePort,
    InitiatingProcessFileName, InitiatingProcessAccountUpn, ReportId

// C - WebDAV fallback process pattern
DeviceProcessEvents
| where Timestamp > ago(30d) and FileName =~ "rundll32.exe"
| where ProcessCommandLine has "davclnt.dll,DavSetCookie"
| where InitiatingProcessFileName =~ "svchost.exe"
| where InitiatingProcessCommandLine has_all ("-k LocalService", "-s WebClient")
```

LOOKBACK	FREQUENCY	THRESHOLD	CORRELATION	EXCLUSIONS
30 days	Manual / daily	None	Analyst-led	After baseline

WHAT A MATCH MEANS

A native alert, a public SMB attempt or the documented WebDAV pattern should be correlated with mailbox evidence.

WHAT IT DOES NOT PROVE

It does not prove a hash was disclosed, relayed or cracked, nor that a user clicked the item.

05

Triage & Investigation

Reconstruct delivery, trigger and authentication evidence.

- 01
- Confirm source event**
Preserve alert ID, device, user, timestamp, destination and raw command line.
- 02
- Inspect mailbox item**
Use the Exchange scan or extended MAPI inspection for an external UNC path.
- 03
- Correlate temporally**
Compare reminder time with public SMB, WebDAV and SMBClient events.
- 04
- Assess credential exposure**
Review NTLM challenge evidence, perimeter logs and possible relay targets.
- 05
- Determine follow-on impact**
Hunt external NTLM auth, mailbox access and permission changes.

EVIDENCE PROFILE	ASSESSMENT	ACTION
MAPI InternetZone UNC + aligned endpoint evidence	Likely exploit activity	Escalate and assess exposure.
MAPI InternetZone UNC only	Targeted; trigger unknown	Correlate endpoint/network.
Public SMB or WebDAV only	Suspicious behavior	Find mailbox and user context.
Click only	Insufficient evidence	Do not attribute the CVE.
Relay or post-exploit artifacts	Likely compromise	Initiate incident response.

ESCALATION CRITERION

Escalate when mailbox evidence confirms an external UNC property and endpoint/network evidence aligns in time, or when credible NTLM relay or post-exploitation artifacts are present.

06

False Positives & Validation

Controls required before promotion beyond hunting.

SCENARIO	LIKELIHOOD	IMPACT	TUNING ACTION
Legitimate SMB to partner or managed public service	Medium	High	Validate owner, destination and approval.
Normal WebDAV client activity	Medium	Medium	Baseline authorized endpoints; retain unknown public targets.
MDO title differs from historical identifier	Medium	High	Enumerate raw AlertInfo titles before tuning.
Approved intranet reminder sound	Low	Medium	Use zone classification and verify host.
Security test or purple-team simulation	Low	High	Tag test but preserve validation evidence.

VALIDATION PROCEDURE

1. Confirm AlertInfo title and ServiceSource values. 2. Measure 30-day public SMB volume. 3. Retain raw WebDAV matches. 4. Use an authorized lab item to align endpoint and mailbox timestamps.

REJECTION / FAILURE

Reject production if alert titles are unstable, mailbox-to-device identity cannot be resolved, SMB attribution is absent, command lines are incomplete or benign activity dominates. Missing Defender coverage or retention prevents operation.

PROMOTION GATE



TEST CASE	EXPECTED RESULT
MDO CVE-specific alert	Query A returns alert metadata and an evidence pivot.
Authorized external SMB attempt	Query B matches; triage identifies legitimate context.
Blocked SMB with WebDAV fallback	Query C matches; no credential leakage is inferred.
Click without MAPI, SMB or WebDAV	Insufficient evidence; no CVE attribution.

07

ATT&CK, Conclusion & References

Coverage statement, residual risk and sources.

TECHNIQUE	NAME	TACTIC	COVERAGE
T1187	Forced Authentication	Credential Access	Partial coverage of public SMB and WebDAV fallback; CVE attribution requires message evidence.

ANALYST CONCLUSION

A layered hunt is feasible; a standalone CVE rule is not yet justified. The most direct confirmation remains an InternetZone value in PidLidReminderFileParameter or a product-native MDO detection. Public SMB and WebDAV are valuable corroboration, not proof of credential leakage.

RESIDUAL RISK

Local PSTs, deleted items, off-network devices, short retention and missing command lines may hide evidence. Legitimate SMB/WebDAV can create matches.

PRIMARY REFERENCES

- Microsoft Incident Response - investigation guidance (24 Mar 2023; updated 4 Dec 2023).
- Microsoft MSRC - CVE-2023-23397 security update advisory.
- CISA - Known Exploited Vulnerabilities Catalog entry, added 14 Mar 2023.
- TrustedSec - technical analysis and auditing concept, 17 Mar 2023.
- Microsoft Learn - AlertInfo, DeviceNetworkEvents and DeviceProcessEvents schemas.
- MITRE ATT&CK - T1187 Forced Authentication.

RECOMMENDED NEXT ACTIONS

1. Execute the three Defender XDR queries over 30-90 days and retain raw matches. 2. Run the Microsoft Exchange scan against the relevant mailbox scope and inspect InternetZone UNC values. 3. Correlate mailbox, SMB/WebDAV and authentication evidence before deciding whether a customer-specific rule is feasible.